Trust Gateway: A Zero Trust Proxy for Dynamic Trust Evaluation and Re-authentication

Huijeong Choi, Jia Hong, Yunui Kang, Dongseok Kim, Seunghyun Yoon
Korea Institute of Energy Technology, KENTECH

Introduction

Static authentication is no longer enough

In most web stacks, passing the login once buys a user unrestricted access for the rest of the session. If the cookie is stolen, if the behavior shifts mid-session, or if the user was never legitimate to begin with, the application has no built-in way to react.

What recent breaches have in common

The majority of 2020–2025 high-profile incidents start with a stolen session token or misused valid credentials. Static auth passes successfully, then anomalous behavior goes undetected.

Zero-Trust system

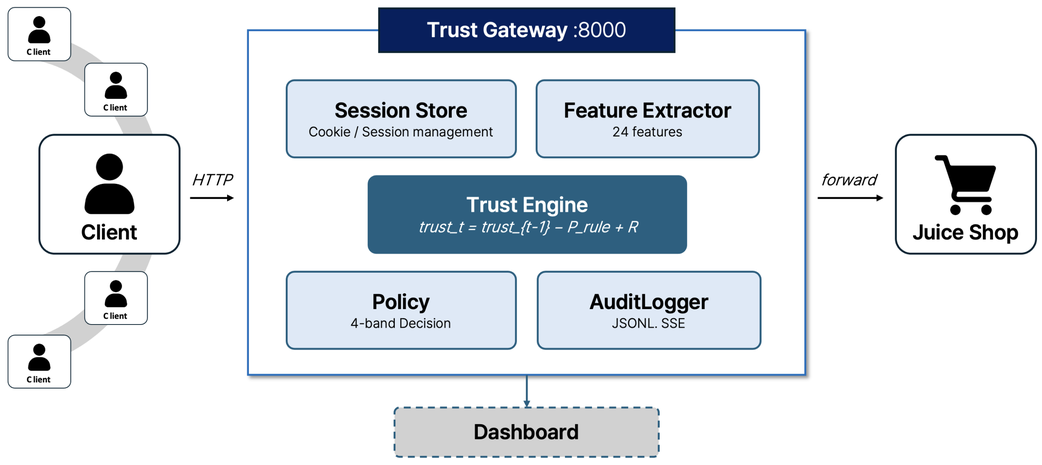
Never trust, always verify - every request is re-evaluated.

Zero Trust is a security model that grants no implicit trust based on network location or a prior login. Every request is authenticated, authorized, and continuously re-evaluated.

Four design decisions any zero-trust system must answer

Q1 How do we quantify trust as a number?
Q2 Among many available features, which become the core metrics?
Q3 Which algorithm decides what is "suspicious"?
Q4 When do we re-authenticate?

Methodology



Overall Architecture

Every HTTP request to OWASP Juice Shop is intercepted, scored from 24 behavioral features nto a continuous trust value in [0, 1], and routed through a four-band policy — Allow · Monitor · Reauth · Block. Trust drifts down with anomalous behavior, recovers slowly on normal use, and is fully restored only by explicit re-authentication.

A. Feature Extractor

A FastAPI middleware intercepts every /app/* request and extracts a 24-field feature record from the request, response, and recent session history (200-entry per-session deque). Each record is enqueued to a background worker that appends it as one line of JSONL.

B. Scenarios & Data collection

Label	Requests	Ratio	Sessions
benign	10,970	69.8%	205
attack	4,690	29.8%	144
합계	**15,721**	**100%**	**410**

Benign (6): normal · search_heavy · power_purchaser · mobile · fast_clicker · bot
Attack (9): aggressive · slow · sqli_slow · xss_aggressive ·path_traversal · idor_aggressive · brute_force. · sqli_mimic ·idor_mimic
Mixed (5): recon_then_exploit · slow_credential_stuffing · graphql_injection · waf_evading · mimic

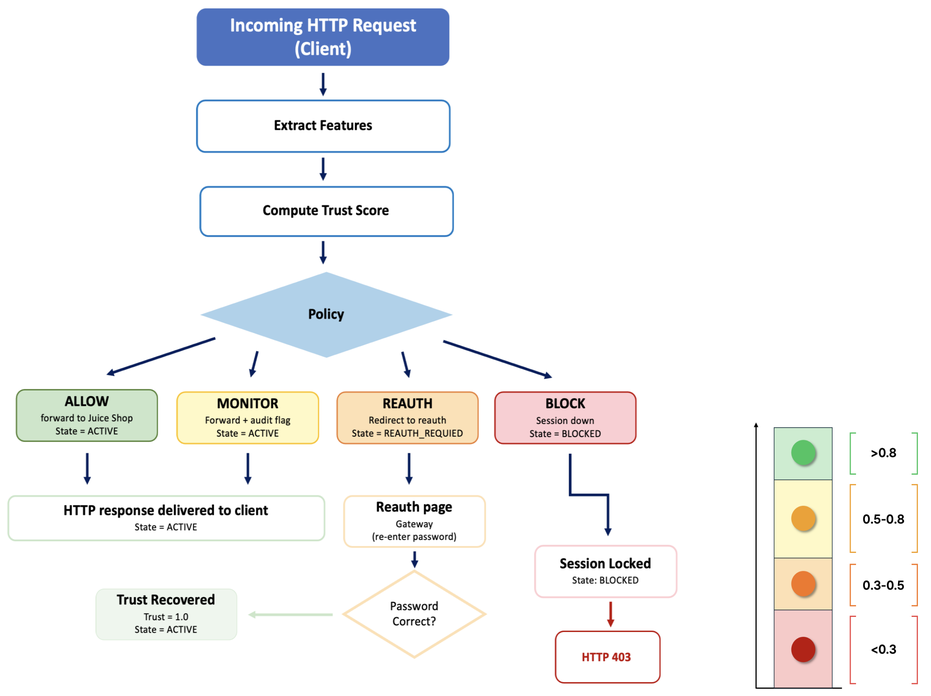
C. Trust Engine

```
trust_t = clip[0,1] (trust_{t-1} – α·P_rule + R),
P_rule = Σ W_i · s_i
R_t = λ · (1 – trust_{t-1})
```

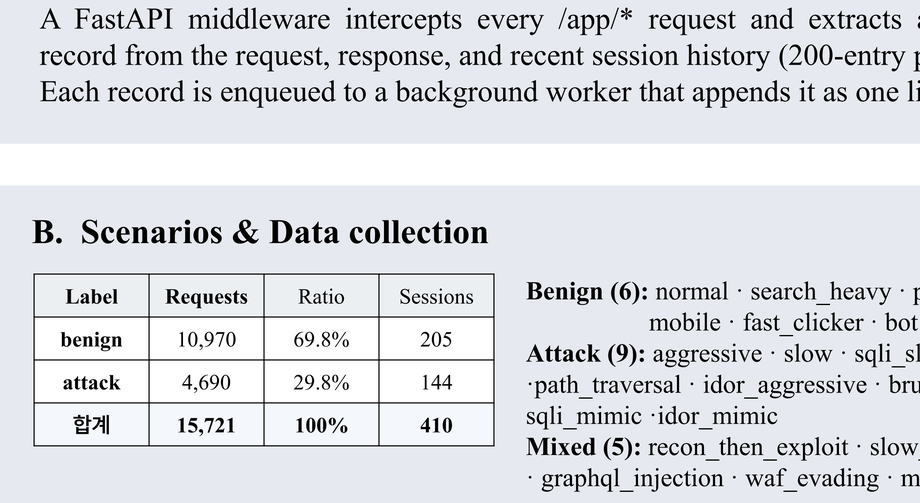
Signal	W_0	Captures
suspicious	0.30	SQLi / XSS / traversal tokens
temporal	0.30	bot-like timing (low mean & std)
query	0.15	long query strings (≥ 50 chars)
binary	0.15	traversal · sensitive ext · URL-encoded
scan	0.05	high unique-path ratio
body	0.05	large POST / PUT body

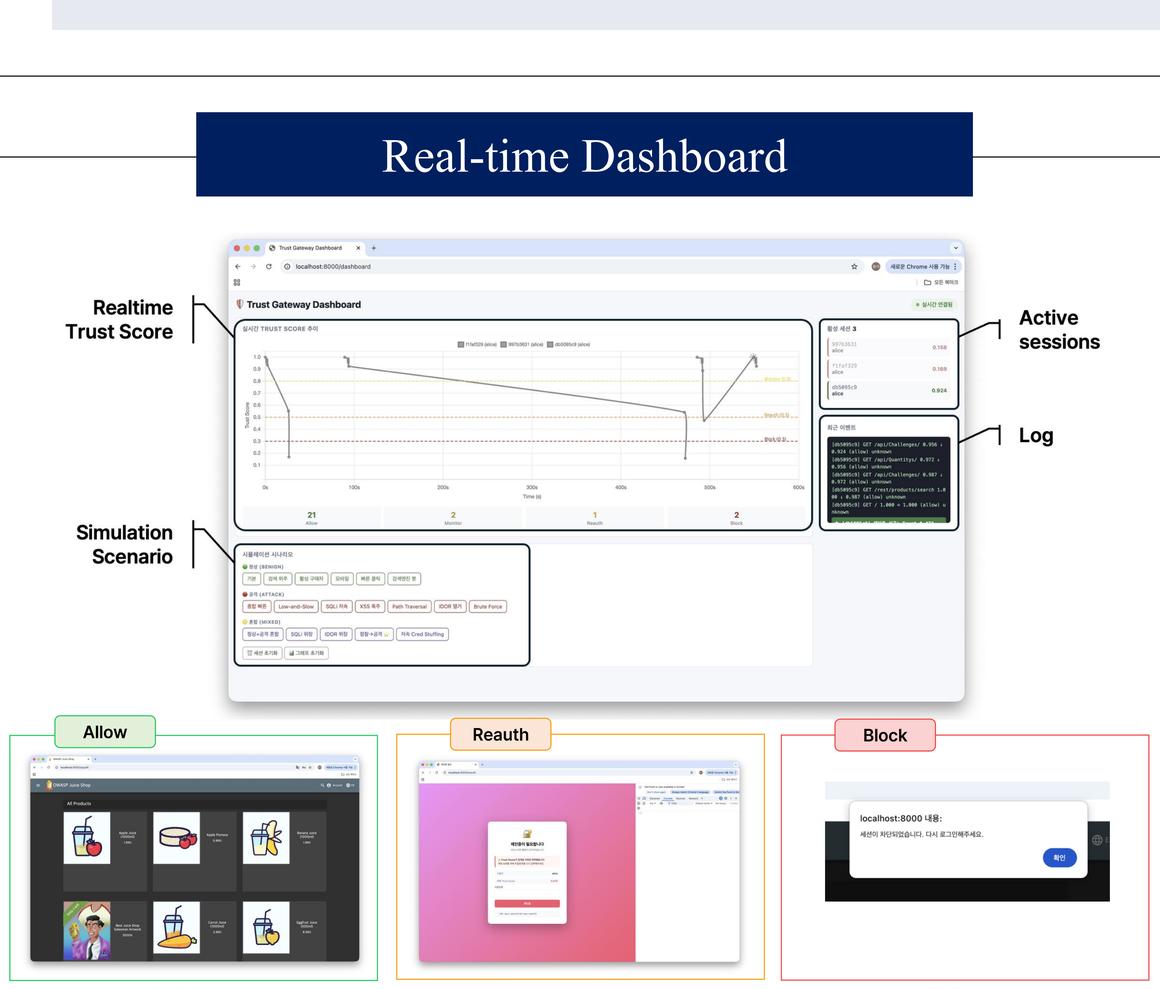
▶ Trust is a continuous score in [0, 1], updated every request by a weighted sum of six interpretable signals.

▶ Weight fitting (SLSQP)
Picked W_0 → SLSQP-fitted W* on 70/15/15 session-stratified split, simplex constraint Σ W = 1, 5 seeds × 10 restarts.



Real-time Dashboard





Contributions

- End-to-end Zero Trust gateway fronting OWASP Juice Shop with per-request scoring & 4-band policy
- JWT session + /reauth UI for seamless recovery
- 18 simulators (6 benign · 9 attack · 3 boundary) for generalization
- SLSQP + simplex fitting (5 seeds × 10 restarts) for retrainable weights
- Real-time SSE dashboard: attack → trust drop → /reauth

Conclusion & Future Work

Limitations

- Simulator-based, not real adversarial traffic
- Mostly binary signals; only L1 Rule active (Markov/ML pending)
- HTTPS approximated via masking, not true TLS capture

Future Work

- Retrain weights on captured real traffic
- Markov sequence modeling against mimicry attacks
- Multi-modal benign behavior learning
- HTTPS replay with actual TLS records